

SOP – Security Incident Response (CFlux)

Version: 1.1 (Entwurf) · Stand: 2026-08-26 · Verantwortlich: Matthias Püski (Incident Lead, IT-Betrieb) · Philipp Amacker (Security-Verantwortlicher)

Regelt Erkennung, Eindämmung, Behebung und Nachbereitung von Sicherheitsvorfällen in der CFlux-Umgebung.

Änderungshinweis (v1.0 → v1.1): Überarbeitung auf Basis des von Rado am 13.07.2026 zusammengefassten Feedbacks (Philipps Prio-1/Prio-2-Punkte sowie Rados AQUIST-spezifische Ergänzungen). Neu bzw. erweitert: §2a, §3, §4, §5.3, §5.6, §6, §7, §8. **Entwurfsstatus – zur Prüfung durch Rado und Philipp vorgelegt.**

1. Zweck & Geltungsbereich

Strukturiertes, schnelles Vorgehen bei Sicherheitsvorfällen, um Schaden zu begrenzen, Beweise zu sichern und Melde-/Datenschutzpflichten einzuhalten.

Beispiele für Vorfälle: kompromittiertes Admin-Konto, geleaktes Secret (**JWT_SECRET**, DB-Passwort, Action1-Token), unbefugter DB-Zugriff, Schadsoftware auf dem Host, Datenabfluss, verdächtige Massen-Logins.

2. Rollen & Alarmierung

Rolle	Aufgabe
Erstkontakt (Bereitschaft/Admin)	Vorfall aufnehmen, Erstbewertung, eskalieren
Incident Lead	Koordination, Entscheidungen, Kommunikation
Datenschutzverantwortlicher	Bewertung Meldepflicht (bei Personendaten)
Geschäftsleitung	Freigabe externer Kommunikation

2a. Entscheidungsbefugnisse

(neu, Antwort auf Philipps Feedback Punkt 1)

Aktion	Ausführung	Freigabe erforderlich von
Vorfall aufnehmen, Erstbewertung	Erstkontakt (Bereitschaft/Admin)	–
Koordination des gesamten Vorfalls	Matthias (Incident Lead)	–
System isolieren/abschalten (Containment)	Matthias (technische Durchführung)	Philipp oder Rado
Benutzerkonto sperren	Matthias	Philipp oder Rado

Aktion	Ausführung	Freigabe erforderlich von
JWT_SECRET rotieren (invalidiert alle Sessions)	Matthias	Philipp oder Rado
Interne Information (Team)	Matthias (Incident Lead)	–
Externe Kommunikation (Kunden, Behörden, Presse)	Rado (Geschäftsleitung)	–
Meldepflicht-Bewertung (Datenschutz)	Philipp (DSB)	–
Wiederinbetriebnahme freigeben	Matthias (Incident Lead)	–

Notfall-Klausel: Bei unmittelbarer Gefahr in Verzug (z.B. aktiver Datenabfluss, der sich durch Warten verschlimmert) darf der Incident Lead (Matthias) Systeme isolieren/abschalten oder Konten sperren **ohne vorherige Freigabe**. Philipp und Rado sind in diesem Fall **unverzüglich, spätestens innerhalb von 15 Minuten**, zu informieren. Die nachträgliche Bewertung der Massnahme erfolgt im Post-Mortem (§5.6).

3. Klassifizierung (Severity)

- **Kritisch (P1):** Aktiver Datenabfluss, Ransomware, Admin-Kompromittierung, Produktivausfall.
- **Hoch (P2):** Geleaktes Secret, unbefugter Zugriff ohne bestätigten Datenabfluss.
- **Mittel/Niedrig (P3/P4):** Verdachtsfälle, Fehlkonfiguration ohne Ausnutzung.

Harte Einstufungskriterien (neu, Antwort auf Rados Punkt 9 – Entwurf zur Prüfung durch Rado/Philipp, da hier bewusst Schwellenwerte vorgeschlagen werden):

Severity	Datenkategorien	Systeme	Betroffene Personen
P1 Kritisch	besonders schützenswerte Daten (Sozial-/Gesundheitsdaten) oder bestätigter Abfluss	Produktivsystem vollständig oder Admin-Ebene kompromittiert	> 10 Personen oder Umfang unklar
P2 Hoch	Stammdaten/Finanzdaten, Verdacht ohne bestätigten Abfluss	Einzelnes Modul/Konto	1–10 Personen
P3/P4	keine Personendaten / interne Testdaten	kein Produktivsystem betroffen	0 Personen

Jährlicher Table-Top-Test: Turnus jährlich. **Verantwortlich: noch nicht festgelegt** – offener Punkt, in einer der nächsten GL-Runden zu klären.

4. Eskalationsmatrix & Kontakte

(neu, Antwort auf Philipps Feedback Punkt 2)

Reaktionszeiten je Schweregrad:

Severity	Erstreaktion	Eskalation an Philipp/Rado	Kommunikationskanal
P1 – Kritisch	innen 30 Min.	innen 1 Std.	Telefon + E-Mail parallel
P2 – Hoch	innen 2 Std. (Kernarbeitszeit) / 4 Std. ausserhalb	innen 4 Std.	Telefon + E-Mail
P3/P4 – Mittel/Niedrig	innen 1 Arbeitstag	nach Bedarf	E-Mail/Ticket

Kontakte:

Rolle	Person	Telefon	E-Mail
Incident Lead	Matthias Püschi	[Mobilnummer einzutragen]	matthias.pueschi@aquist.ch
Security-Verantwortlicher / DSB	Philipp Amacker	[Mobilnummer einzutragen]	philipp.amacker@aquist.de
Geschäftsleitung	Radovan Radojevic	[Mobilnummer einzutragen]	radovan.radojevic@aquist.de

Mobilnummern bewusst nicht eingetragen – bitte direkt im Dokument ergänzen. Aktuell kein separater Team-Chat-Kanal für Vorfälle vorhanden; Telefon ist im Ernstfall Pflicht, nicht nur E-Mail (siehe auch §7).

5. Ablauf (6 Phasen)

5.1 Erkennen & Melden

- Auffälligkeit (Logs, Meldung, Monitoring) dokumentieren: Zeit, Beobachtung, Quelle.
- Incident Lead informieren, Severity festlegen, **Incident-Ticket** eröffnen.

5.2 Eindämmen (Containment)

- Kompromittiertes **Konto sofort deaktivieren** (SOP Benutzer- & Zugriffsverwaltung).
- Bei Verdacht auf Token-Missbrauch: **JWT_SECRET rotieren** → invalidiert alle Sessions.

```
# In .env neuen starken Wert setzen, dann:
docker-compose up -d backend
```

- Bei P1 ggf. System vom Netz nehmen / Frontend stoppen:

```
docker-compose stop frontend backend
```

- **Beweise sichern, bevor bereinigt wird** (siehe 5.3): Logs/Volumes nicht überschreiben.
- Freigaben für diese Massnahmen gemäss §2a beachten (inkl. Notfall-Klausel).

5.3 Beweissicherung

```
# Logs sichern
docker-compose logs --no-color > incident_logs_$(date +%F_%H%M).txt
# DB-Schnappschuss (forensisch, vor Änderungen)
docker exec timetracking-db pg_dump -U timetracking -d timetracking -F c -f
/tmp/incident.dump
docker cp timetracking-db:/tmp/incident.dump ./incident_$(date +%F).dump
```

- Zeitstempel, betroffene Konten, IPs, Auffälligkeiten festhalten.

Verantwortlichkeit & Chain-of-Custody (neu, Antwort auf Philipps Feedback Punkt 5):

- **Verantwortlich für Beweissicherung:** Matthias (Incident Lead); bei Abwesenheit jede Person mit Admin-Zugriff vor Ort.
- Jede gesicherte Datei mit Zeitstempel, Ersteller und Ablageort dokumentieren.
- Prüfsumme der gesicherten Dateien bilden, um spätere Unverändertheit nachzuweisen:

```
sha256sum incident_logs_*.txt incident_*.dump >
incident_evidence.sha256
```

5.4 Beheben (Eradication)

- Ursache beseitigen (Schwachstelle patchen, Fehlkonfiguration korrigieren).
- **Alle betroffenen Secrets rotieren:** `JWT_SECRET`, `POSTGRES_PASSWORD`, Action1-Token, betroffene Benutzer-Passwörter (Reset erzwingen).
- Schadsoftware/Manipulationen entfernen; ggf. aus sauberem Stand neu aufsetzen.

5.5 Wiederherstellen (Recovery)

- Aus **verifiziert sauberem** Backup wiederherstellen (Betriebs-SOP §6/§11).
- Health-Checks, Stichproben, verstärktes Monitoring in den Folgetagen.
- Konten wieder freischalten, sobald sicher.
- Freigabe zur Wiederinbetriebnahme gemäss §2a: Incident Lead (Matthias).

5.6 Nachbereitung (Post-Incident)

- **Datenschutz-Bewertung:** Waren Personendaten betroffen? → Meldepflicht prüfen. **DSGVO: 72 Std.** an Aufsichtsbehörde bei Risiko; Betroffene ggf. informieren (siehe SOP Datenschutz).
- Post-Mortem: Zeitleiste, Ursache, Wirkung, Sofort- und Dauermaßnahmen.
- Lessons Learned in SOPs/Monitoring einarbeiten.

Prozess & Verantwortlichkeiten (neu, Antwort auf Philipps Feedback Punkt 6):

- **Verantwortlich für Post-Mortem:** Matthias (Incident Lead). Teilnahme Philipp immer, Rado bei P1/P2.
- **Termin:** Post-Mortem innerhalb von **5 Arbeitstagen** nach Abschluss des Vorfalls.
- **Massnahmen-Tracking:** Korrekturmassnahmen mit Verantwortlichem und Termin dokumentieren (z.B. als Ticket).
- **Wirksamkeitskontrolle:** nach 30 Tagen prüfen, ob die Massnahmen wirken.

6. Runbooks für Standardszenarien

(neu, Antwort auf Philipps Feedback Punkt 3)

Runbook A – Kompromittiertes Benutzerkonto

1. Konto sofort **deaktivieren** (nicht löschen) – SOP Benutzer-Zugriffsverwaltung §6.
2. Audit-Log prüfen: welche Aktionen wurden mit dem Konto durchgeführt?
3. Passwort-Reset erzwingen – SOP Passwort-Reset §5.
4. Nur bei Verdacht auf weitreichenden Missbrauch: **JWT_SECRET** rotieren (Freigabe gemäss §2a).
5. Betroffene Person informieren, Vorfall dokumentieren.

Runbook B – Kompromittiertes Administratorkonto

1. Sofort **JWT_SECRET** rotieren (Freigabe/Notfallklausel gemäss §2a).
2. Admin-Konto deaktivieren.
3. **Alle** anderen ADMIN-Konten prüfen – wurden neue Admins angelegt? (Audit-Log)
4. Passwort aller Admin-Konten zurücksetzen.
5. DB-Zugriffslogs auf ungewöhnliche Queries prüfen.
6. Beweise sichern (§5.3) **vor** jeder Bereinigung.

Runbook C – Datenabfluss

1. Betroffene Systeme/Datensätze identifizieren.
2. Containment: Zugriffsweg schliessen (Konto sperren / System isolieren, je nach Ursache).
3. Beweise sichern (Logs, DB-Snapshot).
4. Datenschutz-Bewertung durch Philipp → SOP Datenschutz §11 (72h-Frist).
5. Kundenvertragliche Meldepflichten prüfen (§8).
6. Umfang dokumentieren: welche Daten, wie viele Personen, welcher Zeitraum.
7. Betroffene informieren (Timing gemäss Rechtslage).

Runbook D – Malware-/Ransomware-Fall

1. Betroffenes System sofort **isolieren** (Docker-Netzwerk trennen / Host vom Netz) – Freigabe/Notfallklausel gemäss §2a.
2. **Nicht** einfach neu starten – kann Spuren vernichten.
3. Beweise sichern (§5.3).
4. Sauberen Backup-Zeitpunkt vor der Infektion identifizieren.
5. System aus **sauberem Stand neu aufsetzen** (nicht "bereinigen") – Betriebs-SOP §11.
6. Alle Secrets rotieren (**JWT_SECRET**, **POSTGRES_PASSWORD**, Action1-Token).
7. Restore aus verifiziert sauberem Backup, Health-Checks.

Runbook E – Cloud-/Servervorfall (Hetzner)

1. Hetzner-Support kontaktieren, Infrastruktur-Status prüfen.
2. Bei Verdacht auf Kompromittierung der Infrastruktur: alle Secrets rotieren.
3. Notfall-Wiederherstellung gemäss Betriebs-SOP §11 (ggf. auf neuem Host).
4. Off-Site-Backup nutzen, sofern vorhanden (aktuell noch nicht umgesetzt – siehe SOP Datenschutz §5).
5. Nutzer über Downtime informieren.

7. Kommunikationswege

(neu, Antwort auf Philipps Feedback Punkt 4)

- **Intern:** Telefon + E-Mail (kein separater Chat-Kanal vorhanden).
- **Extern (Kunden, Behörden, Presse):** ausschliesslich über Rado (Geschäftsleitung) freigegeben.
- **Ausserhalb Arbeitszeit:** gleiche Eskalationswege wie in §4 (Telefon + E-Mail).
- *Empfehlung:* Perspektivisch einen dedizierten Incident-Kanal (z.B. Teams-Gruppe) einrichten – aktuell nicht vorhanden, daher im Ernstfall Telefon Pflicht.

8. Kundenvertragliche Meldepflichten

(neu, Antwort auf Rados Feedback Punkt 8)

Offener Punkt: Die genauen vertraglichen Meldefristen gegenüber Lonza und Novartis bei einem Sicherheitsvorfall sind aktuell **nicht bekannt/dokumentiert**. Empfehlung: Verträge sichten, Fristen hier nachtragen.

Übergangsregel bis dahin: Der Kunde wird im Zweifel unverzüglich, spätestens innerhalb von 24 Std. nach Bestätigung des Vorfalls informiert – auch ohne bekannte exakte Vertragsfrist.

9. Präventive Härtung (Referenz)

- Starke, einzigartige Secrets in `.env`; Default-Passwörter (`timetracking123`, `admin123`) vor Produktion ändern.
- `NODE_ENV=production`, HTTPS/Reverse Proxy, korrektes `CORS_ORIGIN`.
- DB-Port nur intern; regelmäßige Basisimage-Updates.
- Regelmäßige Zugriffs-Rezertifizierung; Audit-Log-Auswertung.

10. Referenzen

- `docs/security.md`, `docs/SECURITY-FIX-2025-12-29.md`, `docs/SECURITY-FIX-2025-12-30.md`
- `docs/serverpulse-security.md`
- SOP Datenschutz, SOP Benutzer- & Zugriffsverwaltung, Betriebs-SOP